LABORATÓRIO DE DESENVOLVIMENTO DE SOFTWARE

RELATÓRIO DE REVISÃO

Grupo / Projeto	Grupo 08 — Gestão de Clínica Veterinária
Issue / Tarefa	I108 — Implementar a autenticação e a gestão de sessão no frontend web (RF001–RF005) (GitHub #33; Pull Request #256)
Sprint / Milestone	Sprint 06 / m4
Executor	Ivan Cristiano Silva Mendes
Revisor	Gonçalo Dinis Magalhães Teixeira
Auditor	Gonçalo Magalhães Ribeiro
Artefacto revisto	Autenticação e gestão de sessão em src/frontend: AuthService (mensagens do login), ApiClient (tempo limite de 30 s e 401 só com token), AuthContext (sessão terminada e permissões), permissoes.ts, componente SoPara, LoginPage, estilos e README, com 2 ficheiros de testes novos e 2 alargados — 13 ficheiros (+430 −23). O arquivo em 04-artefactos-tecnicos/04.14-frontend-web/m4-v01 é feito na entrega da M4, como indica o Backlog.
Origem no repositório	Ramo 33-i108-implementar-a-autenticação-e-a-gestão-de-sessão-no-frontend-web-rf001rf005; Pull Request #256; commit único 9334b62 (autor 2026-11-09 22:43 UTC; reposto sobre o develop a 2026-11-10 00:22 UTC, depois do merge da I107) sobre develop 2f85350 (o develop atual), ainda não integrado.
Data da revisão	Verificações independentes do Revisor a 2026-11-10, sobre o commit 9334b62; relatório emitido e entregue ao Auditor a 2026-11-10, à hora da assinatura digital.
Versão do relatório	v01

1. Âmbito e método

Revisão da autenticação e da gestão de sessão do frontend web face aos 6 critérios de aceitação e às 3 verificações do Revisor da I108 no Backlog de Projeto v04 (aprovada como Ready no Backlog Refinement de 2026-11-07), aos requisitos RF001 a RF005 e ao UC01 (fluxos A1 a A3 e exceções), à Definition of Done do G08 para código, ao Modelo de Classes do Frontend Web v03 (secções 12, 13, 14 e 19) e à Documentação da API v03 (secção 5 e EP-001 a EP-003). Foram lidos o PR #256 (descrição, evidências e decisões) e o código, e comparados com o backend do develop. A verificação foi feita numa cópia de leitura do ramo, sem alterar o repositório de trabalho nem criar commits: npm ci, build, lint, format:check, testes unitários e testes Playwright; e 24 verificações no navegador (Playwright, Chromium) com a aplicação em execução contra uma API simulada que devolve as respostas e os erros documentados na API v03, incluindo revogação de tokens, resposta lenta e servidor desligado (anexo A.3). Os ficheiros de apoio usados na verificação foram apagados no fim.

2. Verificações realizadas

N.º	Verificação	Método e evidência	Resultado
1	Nome, pasta, ramo e PR	PR #256 «Closes #33», com o commit único 9334b62 «feat(web): autenticação e gestão de sessão, permissões por perfil [I108]» sobre o develop atual (2f85350, merge da I107), sem conflitos: 13 ficheiros, todos em src/frontend. O código fica em src/frontend, como prevê o Backlog; o arquivo em 04.14-frontend-web/m4-v01 é da entrega da M4.	Cumpre, com melhoria (M2)
2	Qualidade do código e testes	Cópia limpa de 9334b62: npm ci, npm run build, npm run lint (--max-warnings 0) e npm run format:check sem erros nem avisos. npm test: 8 ficheiros, 67 testes aprovados (novos: permissoes, AuthService, tempo limite e 401 do	Cumpre, com melhoria (M6)

N.º	Verificação	Método e evidência	Resultado
		ApiClient, rotas com sessão expirada, fim de sessão e endereço direto). Testes Playwright (tests/login.spec.ts): 2 aprovados no Chromium. Node.js 22.23 e npm 10.9.	
3	CA 1 — só as operações da API; perfis internos; Cliente sem acesso	Os pedidos feitos pela aplicação são só POST /auth/login, GET /auth/me e POST /auth/logout (EP-001 a EP-003). Os 4 perfis internos entram e veem o seu menu (anexo A.3). Login válido de um Cliente: POST /auth/logout com o token, mensagem «Os Clientes não têm acesso à aplicação web. Utilize a aplicação móvel.» e nada guardado em sessionStorage (UC01 A2, RNF003).	Cumpre
4	CA 2 — credenciais inválidas e conta bloqueada sem revelar o campo	Palavra-passe errada e e-mail inexistente mostram a mesma mensagem, «Email ou palavra-passe incorretos.» (401); conta bloqueada mostra «Esta conta está bloqueada. Contacte o administrador da clínica.» (403); campos em falta mostram «Indique o email e a palavra-passe.» (400). As mensagens são fixas no AuthService, de propósito, e não usam o detail da API.	Cumpre, com melhoria (M3)
5	CA 3 — fim de sessão com a API e sem reutilização	Terminar sessão chama POST /auth/logout, limpa sessionStorage e o token do ApiClient e leva a /login. Com o botão Voltar (uma e duas vezes) a aplicação fica em /login. O token antigo, usado depois em GET /auth/me, recebe 401.	Cumpre
6	CA 4 — credencial expirada ou revogada	Tokens revogados no servidor e página recarregada: GET /auth/me recebe 401, a sessão é limpa e o ecrã de login mostra «A sua sessão terminou. Inicie sessão novamente.»; o aviso desaparece no novo início de sessão. Um 401 num pedido sem token (login) não é tratado como sessão terminada. Os testes do ApiClient e das rotas cobrem o 401 num pedido feito durante a utilização.	Cumpre
7	CA 5 — mensagens em português, carregamento e falha de ligação	Durante o pedido o botão mostra «A entrar…» e fica inativo, e os campos continuam editáveis. Resposta que não chega: ao fim de 30 s aparece «O servidor demorou demasiado a responder. Tente novamente.» e o botão volta a ficar ativo. Servidor desligado: «Não foi possível contactar o servidor. Verifique a ligação.». Restantes erros com a tradução da I107.	Cumpre
8	CA 6 — rotas e menus por perfil, também por endereço direto	Endereço direto a rotas de outros perfis leva a /acesso-negado: Administrador em /pacientes, /agenda e /pacientes/1/registo; Rececionista em /funcionarios, /clinica, /pacientes/1/registo e /pacientes/1/vacinacao; Veterinário em /funcionarios, /clientes, /agenda/nova e /preparacao; Auxiliar em /agenda, /pacientes, /clientes e /pacientes/1/vacinacao. Menus iguais à matriz da secção 12 do Modelo de Classes.	Cumpre

Nº	Verificação	Método e evidência	Resultado
9	Verificação do Revisor 1 — clone limpo e cada fluxo com cada perfil	Clone limpo de 9334b62 com npm ci e npm run dev; cada fluxo percorrido com Administrador, Rececionista, Veterinário, Auxiliar, Cliente e conta bloqueada contra a API simulada com o contrato da API v03 (anexo A.3). O Executor fez a mesma verificação contra o backend local com os dados de demonstração (I061), com capturas de cada perfil no PR.	Cumpre
10	Verificação do Revisor 2 — sessão expirada, fim de sessão com Voltar e endereço direto	Feito: ver CA 3 (fim de sessão e Voltar), CA 4 (sessão revogada) e CA 6 (15 rotas de outros perfis por endereço direto, todas para /acesso-negado).	Cumpre
11	Verificação do Revisor 3 — regras de negócio no cliente e endpoints fora do contrato	Só EP-001 a EP-003. permissoes.ts e SoPara só mostram ou escondem opções, como pede a secção 19 (critério 4) do Modelo de Classes; a autorização continua na API. A matriz de permissoes.ts bate certo com as secções 12 e 13 (validação pedida pelo Executor), com a ressalva de M4.	Cumpre, com melhoria (M4)
12	Evidências do Executor	PR com o código, os registos de npm ci, build e lint, capturas do ecrã de login, do menu de cada perfil, do Cliente e dos erros (palavra-passe errada, conta bloqueada e acesso negado), a tabela de verificação manual por perfil e por operação e as divergências e decisões (permissões, mensagens fixas, Cliente, token e tempo limite). Três operações da tabela estão marcadas «Não verificado manualmente»: fim de sessão com Voltar, sessão expirada e backend desligado.	Cumpre, com melhoria (M1)
13	Segurança e Definition of Done	Sem segredos no repositório (as palavras-passe das contas estão no ficheiro de credenciais da submissão); token só em sessionStorage e ausente da consola; mensagens do login sem revelar se o e-mail existe. Compila e passa na verificação local. npm audit igual ao da I107 (aviso moderado do minimatch, só em desenvolvimento).	Cumpre
14	Prazos	Prazo do Executor: 2026-11-10 17:30 (Sprint Backlog do S06 v01). Commit de 2026-11-09 22:43 UTC, reposto sobre o develop a 2026-11-10 00:22 UTC, dentro do prazo. Revisor: relatório emitido a 2026-11-10, menos de 24 h depois e antes do limite de 2026-11-11 17:30.	Executor: dentro do prazo · Revisor: dentro do prazo

3. Defeitos e melhorias

Defeitos (correção obrigatória): nenhum identificado na versão revista (commit 9334b62).

Propostas de melhoria (não obrigatórias, não penalizam o Executor):

Ref.	Descrição	Seguimento
M1	Na tabela de verificação manual do PR, três operações estão «Não verificado manualmente» (fim de sessão com Voltar, sessão expirada e backend desligado), embora o Backlog peça os fluxos verificados manualmente contra o backend. O Revisor verificou-as	Executor, no PR (recomendado antes do merge).

Ref.	Descrição	Seguimento
	(anexo A.3). Completar a tabela com a verificação contra o backend local.	
M2	A descrição do PR ainda diz que o ramo contém os commits da I107 e que o rebase será feito depois do merge; o rebase já foi feito (commit único sobre 2f85350). Atualizar a frase.	Executor, no PR.
M3	As mensagens usam «Email»; a Especificação de Requisitos, a API v03 e o resto da interface escrevem «e-mail», a forma do português europeu. Alinhar nas mensagens e na etiqueta do campo.	Executor (pode ser feito antes do merge).
M4	registarApoioNaoClinico está aberto a todos os Auxiliares, mas só os que têm podeRegistarApoio podem registar apoio (secção 13.4 do Modelo de Classes; EP-006/EP-007). O GET /auth/me não devolve esse campo, por isso a interface não o sabe. Registar a limitação em permissoes.ts e garantir que o W12 trata o 403 da API; ou propor o campo no EP-003 (alteração à API).	Executor da I114 (W12) / grupo.
M5	Tempo limite de 30 s nos pedidos: decisão do Executor, registada no PR. Referir no Plano de Testes do Frontend Web (condição CT-WEB-TRV-05, falha de ligação) na próxima versão.	Executor da I043 (próxima versão).
M6	Em ApiClient.ts, a constante TEMPO_LIMITE_PEDIDO_MS ficou entre o comentário de documentação da classe ApiClient e a classe, pelo que esse comentário passa a documentar a constante. Mover a constante para antes do comentário.	Executor (pode ser feito antes do merge).

4. Desvios de processo

Sem desvios de processo do Executor: o ramo da I108 partia da I107 e foi reposto sobre o develop depois do merge da I107 (PR #255), ficando com um único commit, como estava previsto. O PR #256 não está integrado: o merge (squash) fica dependente da autorização do Auditor, conforme o fluxo do grupo.

5. Classificação do Executor e conclusão

Categoria de qualidade proposta	Aceite sem correções obrigatórias (Q = 100%).
Atraso	Sem atraso do Executor: commit de 2026-11-09 22:43 UTC, reposto sobre o develop a 2026-11-10 00:22 UTC, antes do prazo de 2026-11-10 17:30.
Conclusão	Revisão concluída sem defeitos obrigatórios. Os 6 critérios de aceitação da I108 estão cumpridos e as 3 verificações do Revisor foram feitas: cada fluxo com cada perfil a partir de um clone limpo; sessão revogada com aviso no login, fim de sessão sem reutilização (também com o botão Voltar e com o token antigo) e 15 rotas de outros perfis por endereço direto para /acesso-negado; só EP-001 a EP-003 e permissões apenas de interface, iguais à matriz do Modelo de Classes do Frontend Web v03. Melhorias M1 a M6 não obrigatórias (M1 recomendada antes do merge). O relatório segue para Auditoria de Qualidade; após a autorização do Auditor, o Revisor integra o PR #256 (squash).

Revisor	Data e hora	Assinatura digital
Gonçalo Dinis Magalhães Teixeira	2026-11-10 — hora conforme a assinatura digital	Assinado por: **Gonçalo Dinis Magalhães Teixeira** Num. de Identificação: 30559150 Data: 2026.11.10 00:41:26+00'00'

Anexo A — Registos de execução e evidências

Síntese da evidência do Pull Request #256 e das verificações independentes do Revisor.

A.1 — Evidência do Executor

PR #256 (Closes #33), ramo 33-i108-...-rf001rf005, commit único 9334b62 (Ivan Cristiano Silva Mendes; autor 2026-11-09 22:43 UTC, reposto sobre o develop 2f85350 a 2026-11-10 00:22 UTC). Descrição com: o que foi feito; registos de npm ci, build e lint; capturas do ecrã de login, do Administrador, da Rececionista, de dois Auxiliares, de dois Veterinários, de três Clientes, de acesso negado, de conta bloqueada e de dados incorretos; tabela de verificação manual com 12 operações (9 OK contra o backend local com os dados da I061, no Firefox; 3 cobertas só pelos testes); divergências e decisões; instruções de teste.

A.2 — Execução local do Revisor (cópia limpa de 9334b62)

npm ci: sem erros. npm run build: tsc -b e vite build sem erros. npm run lint: 0 erros e 0 avisos. npm run format:check: todos os ficheiros com o estilo do Prettier. npm test: 8 ficheiros e 67 testes aprovados. Playwright (tests/login.spec.ts, Chromium): 2 testes aprovados. Node.js 22.23 e npm 10.9.

A.3 — Verificações no navegador (Playwright 1.64, Chromium)

Aplicação arrancada com npm run dev e VITE_API_URL a apontar para uma API simulada com o contrato da API v03: EP-001 a EP-003, contas dos 4 perfis internos, de um Cliente, de uma conta bloqueada e de uma conta cuja resposta demora 40 s; erros no formato { code, message, detail }; revogação de todos os tokens a pedido; e servidor desligado no fim.
Resultados: palavra-passe errada e e-mail inexistente → «Email ou palavra-passe incorretos.»; conta bloqueada → «Esta conta está bloqueada. Contacte o administrador da clínica.»; Cliente → POST /auth/login e POST /auth/logout, mensagem da aplicação móvel, /login e sessionStorage vazio. Menus: Administrador /clientes (Clientes, Funcionários, Clínica e horários); Rececionista /agenda (Agenda, Pacientes, Clientes); Veterinário /agenda (Agenda, Pacientes); Auxiliar /preparacao (Preparação de consultas). Endereço direto: 15 rotas de outros perfis → /acesso-negado (lista em CA 6). Rececionista: localStorage vazio, sessionStorage só com clinica.sessao, token ausente da consola; pedidos feitos só a POST /auth/login, GET /auth/me e POST /auth/logout; terminar sessão → /login e sessionStorage vazio; Voltar uma e duas vezes → /login; token antigo em GET /auth/me → 401. Administrador: tokens revogados e página recarregada → /login com «A sua sessão terminou. Inicie sessão novamente.»; novo login → /clientes sem aviso. Conta lenta: durante o pedido, botão «A entrar…» inativo e campos editáveis; ao fim de 30 s, «O servidor demorou demasiado a responder. Tente novamente.» e botão ativo. Servidor desligado → «Não foi possível contactar o servidor. Verifique a ligação.».